

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
September 2025	All	All	Jen Daniels	Updated to align with CIC process changes
June 2025	All	All	Jen Daniels	Aligned RAE to SDE: BPO-Dand aligned control assessment questions and tests to RAE
May 2024	All	All	Wolfgang Stengel	Global Delivery Center (GDC) replaced with Client Innovation Center (CIC)
May 2024	Process and Objective	Reference Material	Wolfgang Stengel	Updated links
May 2024	Control Assessment Questions	Primary and Secondary tests	Wolfgang Stengel	Re-aligned primary and secondary tests in-line with updated Risk Area Evaluations
May 2024	Process and Objective	Audit Program Risk Alignment	Wolfgang Stengel	Multiple updates to Risk Area Evaluations (RAEs)
April 2023	Data Security & Privacy	PP001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment	4
PLANNING: Data Analysis	5
PLANNING: Reference Material	6
PLANNING: Fraud Template	9
CONTROL ASSESSMENT QUESTIONS	10
Key Control Question: 1. Delivery Management	10
Primary Test: Contract Requirements (SD001.P)	11
Primary Test: Contract Performance Measurements (SD002.P)	13
Primary Test: Separation of Duties (SD003.P)	15
Primary Test: System, Application, and Data Access (SD004.P)	16
Primary Test: Documents of Understanding (SD005.P)	18
Secondary Test: Business Continuity Planning (SD006.S)	19
Key Control Question: 2. Data Security and Privacy	22
Primary Test: Data Protection and Privacy (PP001.P)	23
Key Control Question: 3. Financial Management	25
Primary Test: Intercompany Recovery Rates Input Process (FM001.P)	26
Primary Test: Internal Billing (FM002.P)	27
Primary Test: Ledger Review (FM003.P)	29
Primary Test: Adjustment and Exception Process for Billing (FM004.P)	31
Primary Test: Over Under Recovery Process (FM005.P)	32
Primary Test: Customer Events (FM006.P)	33
Primary Test: Capital for Employees and Subcontractors (FM007.P)	34
Primary Test: Measurements, and Scorecards (FM008.P)	35
Key Control Question: 4. Resource Management	36
Primary Test: Utilization / Capacity Planning (RM001.P)	37
Primary Test: Onboarding (RM002.P)	38
Primary Test: Off Boarding (RM003.P)	39
Primary Test: Procurement and Subcontractor Management (RM004.P)	40
Key Control Question: 5. Labor Claiming	42
Primary Test: Applicable Time/Labor Claiming Tool (LC001.P)	43
Key Control Question: 6. Asset Management	44
Primary Test: Asset Management (AM001.P)	45

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PROCESS AND OBJECTIVE

To serve as reference for service delivery support out of a cost center or client innovation center (CIC). Also includes service delivery support for standalone and portfolio combined Application Services (AS) audits.

Cost Center

The Service Delivery Cost (SDC) process includes the architecture, management, and support for a broad scope of consulting services provided for IBM commercial and internal accounts. The SDCO process is designed to support the consulting services with an emphasis on growth of customers served, improved efficiency, and quality enhancements

CIC, AS Delivery

Service delivery operations combine high quality industry and consulting skills with lower cost of remote delivery. The client relationship and contract risk management reside with the GEOs. Projects are delivered primarily out of Sectors and services lines in the center. (This may apply to larger center more than smaller center). The services are provided in the following service lines

- Application Operations
- Hybrid cloud and data
- Business Applications
- Strategy and Transformation
- Cyber Security

The CIC offers inter-company services on a rate-based Cost Recovery Model. The Financial and Cost management of the center are at the center level, financial management of project is at GEO. IBM uses consistent processes and tools in a global delivery model that involve a diversified and mature set of delivery centers around the world. Processes include:

- Resource and Capacity planning
- Asset Management
- Business Operations - Seat allocation process
- Sub-Contractor Operations

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PLANNING: Audit Program Risk Alignment

Service Delivery External – Application Services (AS)

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Delivery Management	High	Delivery Management	SD001.P, SD002.P, SD003, SD004.P, SD005.P, SD006.P
Data Security and Privacy	High	Protection and Privacy	PP001.P
Financial Management	High	Financial Management	FM001.P, FM002.P, FM003.P, FM004.P, FM005.P, FM006.P, FM007.P, FM008.P
Resource Management	High	Resource Management	RM001.P, RM002.P, RM003.P, RM004.P
Labor Claiming	Medium	Labor Claiming	LC001.P
Asset Management	Medium	Asset Management	AM001.P

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
IBM Labor Claiming (CLAIM)	Obtain a list of employees and contractors who claimed hours in the Intranet Labor Claiming Tool (ILC) for the projects and contracts associated with the services being provided.	Duplicate hour claiming; claiming hours on multiple contracts; hours claimed while on vacation; hours claimed for nonexistent or separated employees	Inaccurate and unauthorized hours charged to the external customer for the work being performed which could lead to customer dissatisfaction and legal issues.
	Obtain employee payable expense requests for Overtime Meals	Claimed overtime meal without OT hours	Employee has been told to not claim hours worked to keep project under budget.
Delivery Center Costs	Obtain a list of costs reported in the ledger for delivery. Verify if costs included in measurement reports matched with those billed to the client.	Understatement or overstatement of costs; generic cost centers or codes	Costs are not being appropriately applied to the contract, projects, or other business units.
EAL Records	Review EAL records for applications being audited to ensure IBM Confidential information is not exposed.	Attachments or documentation designated by data owner as IBM Confidential could be viewed by all IBM users.	Users without a current business need could have access to view IBM Confidential information could result in misappropriation or unauthorized disclosure.
Access to IBM applications and databases	Obtain a list of all employees who left the company during the audit period, including accesses granted and access removal details.	Inappropriate accesses; access after separation or job change; inadequate level of access	Ineffective access control process could affect customer satisfaction, expose confidential information, lead to possible contract termination, and result in financial loss.
Data element identification	Determine if data elements are protected by country laws as sensitive personal information (SPI) or protected health information (PHI).	SPI or PHI could be exposed to misuse.	Failure to implement the correct controls on SPI or PHI could result in legal action against IBM.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PLANNING: Reference Material

Terminology Glossary

The following terms, alphabetically organized, are use throughout the documents:

- Link does not exist. May need to add EAL links
- Centrally Run Application
Refers to an application designed for global use across the organizations. These centrally run applications sometimes need to be customized to meet local requirements and business needs.
- Sensitive Programs and Associated Sensitive Data
Sensitive programs and associated sensitive data are any program whose unauthorized modification or use could cause serious loss of IBM Corporation's physical or financial assets, and this loss cannot be controlled through normal application or manual controls. Additional Responsibilities as well as the definition itself are defined in the ASCA standard.

Worldwide References

Corporate Instructions, Guidelines, and Websites:

<https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-instructions>

- CIO 122: IBM Worldwide Records Management
- CIO 127: IT Business Continuity
 - IT Continuity Standard - https://w3.ibm.com/#/support/article/cio_standards/it_continuity_standard
 - Business Continuity Planning Corporate Guidelines - https://w3.ibm.com/#/support/article/cio_standards/bpbc?lang=en
- CIO 129: Business Transformation Management System
- FIN 151: Application Systems Control and Auditability (ASCA)
 - ASCA website --> <https://w3.ibm.com/w3publisher/asca>
 - ASCA Procedures Manual --> <https://w3.ibm.com/w3publisher/asca/procedures-manual-200>

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PLANNING: Reference Material (Continued)

- Finance 176: Protecting e-Payment Information
- Legal 116: Classification and Control of IBM Information

Corporate Security Standards, Guidelines, and Manual:

- IT Standards Homepage --> <https://pages.github.ibm.com/ciso-psg/main/>
 - IT Security Standard --> <https://pages.github.ibm.com/ciso-psg/main/standards/itss.html>

GDPR – General Data Protection Regulation- General Legal Requirements -->

- Data Privacy within IBM --> <http://w3.ibm.com/ibm/privacy/index.html>
- Home: <https://w3.ibm.com/ibm/privacy/knowledge-base/knowledge-base-a-z>
- GDPR: <https://w3.ibm.com/ibm/privacy/gdpr>

Subcontractor Procurement Reference Information

- Global Accounts Payable - Home Webpage
<https://w3.ibm.com/w3publisher/global-accounts-payable>
- Global AP - Invoice Payment Verification Process
<https://w3.ibm.com/w3publisher/global-accounts-payable/accounts-payable-process/general-invoice-payment/ipvn>
- Procurement Web site
<https://w3.ibm.com/w3publisher/procurement-ibm>

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PLANNING: Reference Material (Continued)

- Global Procurement Intranet Portal/Blue Book
<https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/blue-book>
The process of selecting qualified suppliers, placing orders to fulfill a business need, monitoring the performance of suppliers.
Procurement activities should conform to the policies outlined in the Procurement Policies and Practices (PP&P) booklet (the blue book).
- HR - You and IBM - Employment – Contractors
<https://w3.ibm.com/youandibm/>

Corporate Instructions, Policies, Standards and Letters

- Corporate Organization Letter 131: "All commitments of IBM funds to external suppliers in exchange for products, services, or intellectual property assets must be approved and effected by a procurement organization that has received a specific delegation of procurement authority from the IBM Chief Procurement Officer or designee."
- Corporate Instruction FIN101: Control of Disbursements
- Corporate Instruction PROC167: Supplier sourced goods and services

Consumption Billing and Chargeback of Usage-based IT Services References

- Corporate Instruction FIN151: Application Systems Control and Auditability (ASCA)
- Corporate Instruction FIN179: Management Self-Assessment of Controls
- Corporate Instruction LEG116: Classification and control of IBM information

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Resource Management and Labor Claiming	On-boarding process	Sample on-boarding for repeated official document numbers to indicate an invalid employee is being paid.
		Data Analytics to evaluate unusual patterns.
Procurement – Kickback, Preferential treatments	Supplier Selection process, Fair value process	Sample subcontractor POs for procurement involvement. Review payment verification process. Review IOI's where applicable.
Procurement - Bypass	Bypass tracking and Review of disbursements	Verify payment made without PO's and payments made on the date the PO was issued.
Direct data updates / Privileged access to production applications	Activity logging and review	Are direct data updates or privileged access logged and reviewed on a periodic basis for unapproved changes?
Activity manipulation	Does the person performing the action being logged have the ability to modify the log or turn off the log	Review log permissions and review process. Look for SOD conflicts and the ability to turn on and off logging.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Objective:

Are services delivered to external customers in accordance with contractual obligations as per account specific governance system based on scope and type of work? Are there adequate measurements and monitoring programs in place to ensure that IBM is delivering services as per client requirements? Are there comprehensive controls in place to safeguard both the customer's data and the customer's assets where applicable?

Risk/Exposure:

Because of the complexity of most solution delivery projects, the execution phase requires a particular focus on IBM performance, versus contract commitments and customer expectations. The lack of project follow-up and of monitoring for subcontracted services, and failure to effectively use or reallocate resources could jeopardize IBM's ability to fulfill the contractual commitments and result in cost overruns, negatively impacting profit.

The CICs provide a wide range of services remotely in skills belonging to the service lines

- Application Operations
- Hybrid cloud and data
- Business Applications
- Strategy and Transformation
- Cyber Security

Specific risks / exposures in relation to the provision of these services include:

- Insufficient understanding of customer requirements could lead to contract requirements not being met in the provision of any of the about services or incorrectly interpreted, resulting in customer dissatisfaction and creating excess expenditures
- Failure to meet established performance targets decreases IBMs ability to provide high quality, low cost services
- The absence of a good internal measurement and controls system created the environment for fraud to occur and could lead to excessive expenditures
- Nonadherence to data privacy laws could result in legal exposure

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Requirements (SD001.P)

Objective:

This topic specifically addresses services being delivered to external customers.

Ensure that changes to the delivery of services requested by the customer were adequately, effectively and timely communicated to delivery teams as per account specific governance process, which should include in-scope and out-of-scope contract changes and terms and conditions changes

Document of Understanding (DOU): It is a document between the service requestor and the delivery center, which indicates high level scope of work. The details of contract performance measurements performed by each delivery center in support of the customer agreement are handled as part of account specific governance processes.

Approach:

For the sample selected from the universe, test against the following criteria:

1. Did the current account specific governance process reflect the agreed scope, timelines with the customer?
2. Did the contract contain an audit clause? If the audit clause has been exercised, were the results reviewed and were appropriate action plans implemented?
3. Did the contract contain customer specific controls to be performed by IBM?
4. Did the contract include exclusivity clauses for employee support?
5. Were contract changes properly approved and communicated to the CIC?
6. Were CIC performance measurements and deliverables, if applicable, for both IBM and the customer specified in the account specific governance process?
7. Were change control put in place to identify the change in scope of work? Were changes to contracts approved and documented prior to the effective date of change? Were exceptions identified and business justification documented?
8. Did the scope of work adequately identify services to be delivered to the client?
9. Was there a process to properly track performance measurement and deliverable management in accordance with contract requirements?
10. Was there a process in place to review, monitor, and implement additional services requested by the client? Ensure this process was part of IBM's methodology to deliver services to external customers.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Requirements (SD001.P)

(Continued)

Transitioning Contracts

1. Were the contracts registered and approved prior to delivery commencement?
2. Were the delivery milestones documented and approved, prior to start of delivery or in accordance with the contract requirements.
3. If applicable, were the DOUs and ICAs approved by all required parties prior to the start of delivery?

Terminated Contracts

1. Were contract terminations performed in accordance with the terms and conditions of the contract or initiated based on an approved addendum/work scope change?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Performance Measurements (SD002.P)

Objective:

This topic specifically addresses services being delivered to external customers.

To ensure conditions of success, as specified in the contract with the customer, were met. This was done through the attainment of contract performance measurements specific to the delivery of services. Failure to meet these measurements could lead to penalties to IBM, customer dissatisfaction, and possible breach of contract.

Approach:

Identify all contractual commitments classified as contract performance measurements from the contract. These are measurable and generally reportable commitments that are made to the customer for services to be provided. These contract performance measurements will be measured against the commitments included in the account specific governance process. The inability to attain these measurements, could result in penalties to IBM or contracts cancelled by the customer. The measurements covered are those specifically tied to the services being delivered to the external customer.

1. From a sample of contract performance measurements with monetary and non-monetary repercussions, review the following:
 - a. Were the results of contract performance measurements reported to the CICs?
 - b. Were the results of contract performance measurements reported to management periodically to ensure proper oversight?
 - c. Were the results of contract performance measurements accurately reported?
 - d. Was root cause analysis completed for contract performance measurements that did not meet the attainments?
 - e. If the contract performance measurements were tied to a breach of contract clause, was there proper oversight over the contract performance measurements not being met to mitigate exposure of recurrence and possible breach of contract?
 - f.
2. Were coherent action plans created? Were these action plans assigned to an owner and with a due date for execution? Was the status of the action plans updated? Were they reported timely to the customer, if required?
3. Were any misses to the contract performance measurements communicated to the concerned parties in a timely manner?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Contract Performance Measurements (SD002.P)

(Continued)

4. Was the risk and issues log (RAIL) maintained and reviewed by the delivery manager responsible or the official delegate as per account governance process? Did the log properly document and track all issues that might interrupt operations or any misses in our contract performance measurements?
 - a. Did each issue have an action plan, owner, estimated date of closure, and severity level assigned to each issue on the issues log?
 - b. Were due date changes tracked in the issues log? Did the log include both the original due date and the new due date? Was there evidence that due date changes were communicated to concerned parties (if applicable) before the official target date expired and documented evidence of concurrence is on file?
5. If applicable, request customer survey results (external / internal) during the audit period. Review process of monitoring and closure of service delivery-related issues from customer feedback surveys.
6. Review the governance model or management system in place to check, report, or monitor contract performance or any internal measurements, if applicable.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management.

Primary Test: Separation of Duties (SD003.P)

Objective:

To ensure proper separation of duties exists so that no individual can control activities within a process to misuse or divert company funds without detection. Essentially, one individual should not be permitted to perform activities which combine custody, transacting and recording of IBM assets.

Risk/Exposure:

Failure to maintain adequate separation of duties could enable individuals to manipulate transactions, conceal errors, or commit fraud without detection

Approach:

1. Request an assessment showing all employees involved in client innovation center process and their related responsibilities. If no assessment exists, determine whether management have alternative methods of identifying potential separation of duties conflicts.
2. Review the responsibilities assigned in the areas related to rates development, billing, measurements, forecasting and capital management for possible separation of duties exposures. Include in the review any update authority to systems, system tables or data. Any individual with capabilities which would allow them to circumvent preventive and detective controls in the processes should be identified and included in test samples.

Verify if there are secondary controls implemented and executed to manage risk for existing conflicts.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS.

Key Control Question: 1. Delivery Management

Primary Test: System, Application, and Data Access (SD004.P)

Objective:

To ensure that access to systems used to deliver services to external customers are controlled in a timely manner, and to prevent unauthorized access to applications and information used to deliver services to external customers. Appropriate management approvals should be granted and documented according to business need. Ensure adherence to Information Technology Security Standards, Computer Security and Use Guidelines.

Password Sharing

To ensure that management approvals are in place before any password sharing takes place and that the process in place should include predefined controls.

- Verify that a process is in place to safeguard data, which is reviewed or stored as part of delivering business process services to external customers.
- Verify accountability for shared userids can be established or effective secondary controls are in place.
- Verify if a process has been implemented to timely revoke accesses no longer required.

Approach:

1. Review and identify a list of key applications and databases used to deliver services to external customers.
2. Review contract clauses related to data protection and accesses granted to IBM employees.
3. Review the processes surrounding access controls for the key applications supporting the audited process. In particular, review access to customer data. Include both IBM and customer systems, applications, and data in scope when appropriate.
4. Review compliance with ASCA and applicable certifications in place for spreadsheets owned by ~~BPO~~ the CICs and used as trusted information sources.
5. Review if an annual process was established to timely revoke accesses no longer required.
6. Review if procedures for maintaining an access / activity log of individual accountability for usage of shared userids (if applicable).
7. Review if password control procedures are in place for shared userids (check-in/check-out).
8. Review if there are procedures for the removal of access and password resets.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: System, Application, and Data Access (SD004.P)

(Continued)

Access Control

1. Obtain a list of applications used and review the process for granting access approvals to ensure that business need/justification was confirmed. Ensure access was approved by appropriate approvers. Review the process for periodic verification of employees and validation of continued business need inline with contractual requirements and IBM's Corporate Instructions. In addition, ensure that access for leavers (including internal transfers) was deleted in accordance with timeliness requirements in IT Security Standards or contracts.
2. From the access lists provided in the universe, was there a periodic business need revision performed by management inline with contractual requirements and IBM's Corporate Instructions?
3. Were system controls and execution in accordance with the contract signed with the customer?

Note: If the delivery center is the party responsible for actual deletion, then testing should cover actual deletion and not the request to delete access.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Primary Test: Documents of Understanding (SD005.P)

Objective:

To determine if line management has established processes and procedures to create and manage documents of understanding and service level agreements when the completion, accuracy, and timeliness of a process is dependent on the input or output of another organization (business unit). Do the DOUs and SLAs include a detailed scope of work, the appropriate business relationships, a system of performance measurements, and supporting documentation requirements to effectively manage the agreements? Is there an established process for reviewing, adjusting, and managing these agreements on a periodic basis? DOUs should be completed during the transition period.

Risk/Exposure:

If management does not have a process for establishing and managing business contingencies via DOUs and SLAs, process dependencies and business results may be adversely impacted. DOU and SLA terms and conditions, including a definition of the scope of work as well as expected deliverables, must be clearly stated, or miscommunications and prolonged disputes between organizations could result and adversely impact the continuity of services.

Approach:

1. Review the process documentation developed by the line organization that defines the management responsibilities for meeting organizational business objectives through relationships with other organizations within IBM.
2. Identify key departmental processes requiring interdepartmental relationships and determine that DOUs or SLAs have been established when the following criteria apply:
 - a. There is a high level of inter-departmental responsibility
 - b. The complexity level of the process is high, or
 - c. A critical dependency exists between functions
3. Develop a list of all DOUs and SLAs that were in effect during the audit period and review the DOUs and SLAs against the following criteria:
 - a. Were DOUs and SLAs current? Were DOUs completed and signed during the transition period?
 - b. Did the agreement clearly define the roles, relationships, and responsibilities of the participating organizations?
 - c. Were the requirements complete, and the deliverables defined and measurable?
 - d. Had line management established a method for validating that services were being received or performed as agreed?
4. Had there been any changes (Interlock Change Documentation) in the process during the audit period? If so, were change control procedures established so that management could request changes and updates to the DOU or SLA? Verify that any adjustments to interlocks are substantiated and properly documented.

Was there evidence that DOUs and SLAs were reviewed and updated on an annual basis?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Secondary Test: Business Continuity Planning (SD006.S)

Note: Business continuity risks become increasingly important in the environment where there are centers of excellence and multiple countries are supported by one center. This should therefore be an important test and considered primary in that environment. IT testing for disaster recovery is handled by the IT audit teams.

You should refer to BPBC127 Guideline for Business Process - Area Business Continuity Planning in the reference section of this audit program, in support of your review.

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Risk/Exposure:

Any material disruption of business operations due to natural or man-made disasters can lead to significant financial loss not only IBM but potentially also for IBM's customers. Many business processes have been centralized, and often operations are conducted in locations which may be susceptible to business disruption. As a result, it is important that business and process owners have developed plans to maintain continuity of business operations in those centralized operations.

Approach:

A guideline has been put in place for process owners providing guidance on business continuity planning (BCP). It should be noted by the audit team that this is a guideline rather than a specific instruction. However, it will act as a guide for you to understand whether key risks have adequately been considered for BCP and enable you to make an informed judgement regarding the risk mitigation in place. Different processes will have their own unique risk profiles regarding the probability and impact of an interruption to business operations. For example, the probability and impact of a business interruption for a process which has been centralized for multiple countries in a location with less-developed infrastructure is likely greater than that of a process supporting only a single country in location with robust infrastructure. As such, auditor judgment will be required to determine how important BCP is for a particular process, as well as to determine the reasonableness of any plans that have been designed by the process owners.

In the initial data request information ask for the process owner to confirm what plans have been implemented to ensure business continuity in the event of a natural or man-made disaster. Review that non-I/T process elements have been adequately considered in the BCP.

The following list of questions has been designed based on the BPBC127 Guideline for Business Process - Area Business Continuity Planning.

1. Has management assessed the risk to business continuity (BC) and identified the key business processes and activities that require formal business continuity planning based on impact to the business.
 - a. Identification and prioritization of business processes' activities in addition to prioritization done through by the Enterprise Process Owner (level 3 plans)
 - b. Understanding and documentation of the potential impact (financial, operational and reputation) to IBM from business disruptions from uncontrolled, non-specific events
 - c. Identification of the legal and regulatory requirements for the institution's business functions and processes
 - d. Review and approval from senior management

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Secondary Test: Business Continuity Planning (RM006.S)

(Continued)

2. For critical business areas and processes, has the maximum acceptable outage (MAO) been established and considered in the BC plan?
 - a. Estimation of maximum allowable outage (MAO), based on the "acceptable level" of losses, associated with the institution's business functions and processes
 - b. Estimation of recovery time objectives (RTOs), recovery point objectives (RPOs), and Maximum Tolerable Downtime (MTD) of applications and supporting technology required for business operations
 - c. If applicable, recommended critical path recovery order
 - d. Reconciled with agreed IT recovery priorities (Business Criticality Values, RTO/MTD)
3. For business areas and processes where there is a business continuity risk, has the BC Plan been created, reviewed, and approved by management?
 - a. The organization shall establish documented procedures for responding to a disruptive incident and how it will continue or recover its activities within a predetermined timeframe. Top management shall review the organization's BCMS, at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.
4. Does the Plan document the specific continuity and recovery actions for all four impact scenarios (workforce, workplace, IT, and regional) that will need to take place to mitigate risk to the business if the impact lasts longer than the documented business' maximum acceptable outage?
 - a. Flexible to respond to unanticipated threat scenarios and changing internal conditions;
 - b. Focused on the impact of various threats that could potentially disrupt operations rather than on specific events;
 - c. Effective in minimizing service disruptions and financial loss through the implementation of mitigation strategies.
5. Does the BC plan clearly identify dependencies such as site resources, IT, suppliers, process interdependencies, partners, non-IT services and been reviewed and synchronized with the appropriate crisis management team?
 - a. An effective BCP coordinates across its many components, identifies potential process or system dependencies, and mitigates the risks from interdependencies.
6. Is there an established, management-endorsed business continuity team to oversee the maintenance, invocation, and execution of the BC plan?
 - a. Defined roles and responsibilities for people and teams having authority throughout an incident
 - b. Additional teams as necessary to facilitate recovery execution per the chosen strategy
7. Are personnel aware and educated on the plan, strategy, and roles?
 - a. Business continuity training should be an integral part of the BCM
 - b. Comprehensive training program should be developed for all employees part / supporting BCP, conducted at least annually, and kept up-to-date to ensure that everyone understands their current role in the overall recovery process.
 - c. An audit trail should be maintained to document management's training efforts.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Delivery Management

Secondary Test: Business Continuity Planning (SD006.S)

(Continued)

8. Is there a regularly executed process for validating the Plan through tests including key elements such as people, technology (data, systems, applications, and telecommunications), and locations that house staff and technology to ensure fit for purpose and alignment with current risks?
 - a. Tests should be based on appropriate scenarios that are well planned with clearly defined aims and objectives that promote continual improvement.
 - b. Produce formalized post-exercise reports that contain outcomes, recommendations and actions to implement improvements and are reviewed with management.
 - c. Tests are conducted at planned intervals and when there are significant changes within the organization or to the environment in which it operates.
9. FOR COMMERCIAL CONTRACTS: Where IBM has customer contracts including business continuity planning, have BC plans been implemented in accordance with contractual obligations?

FOR CUSTOMERS WITH REGULATORY REQUIREMENTS: Does the plan accommodate and account for the any unique rigor or accommodations for the regulatory body.

- a. Adherence with contractual obligations contained in the IBM Responsibilities section of the Schedule or similar agreement. Including communication, recovery parameters, specialized technical designs.

Special considerations to meet unique regulatory requirements (HIPAA – US Healthcare has unique wording on backup, protection, and availability of data).

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Objective:

To ensure that access to systems used to deliver services to external customers is controlled in a timely manner, and to prevent unauthorized access to applications and information. To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) / disaster recovery plans (DRP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Risk/Exposure:

Unauthorized persons may gain access to applications and its resources enabling them to enter unauthorized transactions or to make unauthorized changes to data or programs. If IBM were unable to recover processing or operating capabilities following disruption due to accident, disaster, or other emergency, obligations to customers may not be met. In addition, ineffective separation of duties could allow unauthorized transactions or fraud to occur. All of these may result in financial loss to IBM and customers.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Protection and Privacy (PP001.P)

Objective:

To verify that a process is in place to safeguard data that is reviewed or stored as part of delivering services to external customers. To ensure that access to systems used to deliver services to external customers is controlled in a timely manner, and to prevent unauthorized access to applications and information. Appropriate management approvals should be granted and documented according to business need. Ensure adherence to Information Technology Security.

Risk/Exposure:

Unauthorized persons may gain access to the application and its resources enabling them to enter unauthorized transactions or to make unauthorized changes to data or programs which may result in financial loss to IBM and customers.

Approach:

Review list of applications and databases used to deliver services to external customers.

Were all necessary ASCA certifications in place for IBM applications, databases, and spreadsheets used as a trusted source of information?

Access Control

1. Review the access controls lists to IBM managed applications and systems to validate that users have an appropriate business rationale.
2. Review access lists to establish business need and verify that periodic continued business need was performed and complete.
3. Verify that management controls and authorization of all access to the application and data can be demonstrated with management awareness and removal of such access is processed when there is no longer a business justification.
4. For systems used in the delivery services, were controls in place to guarantee physical and logical security?
5. Were system controls and execution in accordance with the contract signed with the customer?
6. Review IBM employee access to customer applications to verify that IBM is approved by the customer (and the company licensing the application, if applicable) to use the applications.

Data Privacy

1. Review the customer's definition of data privacy and the customer's documentation requirements to protect customer and end users' information. Validate that there are controls around this process to certify that IBM is sufficiently protecting information per customer requirements.
2. Review documentation to ensure proper classification of information. Customer requirements for classification of customer confidential documentation should be identified in the signed contract. Ensure that there are controls in place to follow customer guidelines for information.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Protection and Privacy

Primary Test: Data Security and Privacy (PP001.P)

(Continued)

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. For all sampled projects request a copy of the DS&P checklist. If no DS&P is applicable than request evidence of a documented justification. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller of Personal Information (PI), request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link:

<https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor of PI, select a sample of products/offerings/services provided for the in-scope activities.

Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

References

IBM Consulting Data Security and Privacy - <https://w3.ibm.com/w3publisher/dsp>

Privacy and Data Protection - <http://w3.ibm.com/ibm/privacy/index.html>

IBM's Data Privacy Policy (Corporate Policy 130) - <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>

IBM Security Standards (IT Corporate Standards) - <https://pages.github.ibm.com/ciso-psg/main/standards/itss.html>

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Objective:

To ensure that accurate financial performance is reported to the management on a regular basis. To ensure that measurements are in place to give management visibility of the results of the operations during the period.

Risk/Exposure:

Inadequate management review may result in financial issues going undetected, root cause analysis not being performed for missed, and timeliness of corrective actions not being taken, leading to potential financial misstatements for IBM.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Intercompany Recovery Rates Input Process (FM001.P)

Objective:

To ensure that management controls are in place for providing inputs to GIC Finance for the development of intercompany cost recovery rates and rates loaded in PACT are as per approval from GIC Finance.

Risk/Exposure:

Inadequate management review may result in rates that do not cover costs and missed plans.

Approach:

For the cost recovery rates, verify:

- Operational parameters, cost trend, next year demand and estimated spends has been obtained timely and analyzed accurately.
- Rate inputs are reviewed by the Consulting CIC and GIC Finance management.
- Rate is approved by the GIC CFO/Controller.
- Billing is based on the published cost recovery rates for the samples selected to test for billing. All billings are post approval of the rates.

Rate changes during the year should be approved by GIC CFO / Controller.

Rate exceptions given to any specific/unique account(s) should be approved by GIC CFO/Controller.

Exchange rate agreements if any should be outlined in the documentation along with impacts.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Internal Billing (FM002.P).

Objective:

To ensure internal billings are processed accurately and in a timely manner and that all costs are properly recovered in accordance with established interlocks and DOUs.

Risk/Exposure:

The absence of completeness controls increases the risk of omitted billings which could impact IBM's cash flow and the accuracy of the financial statements. These controls also alert management to the possibility of file tampering. Delayed and inaccurate billing directly affects IBM's cash flow, and adversely impacts the accounts receivable process, the integrity of the financial statements, and the corporation's image in the marketplace.

Approach:

Tailor the approach based on the environment.

To ensure complete understanding of all aspects of the billing process, consider flow-charting the complete billing process and documenting needed and existing control points. Test each of the different types of cost recovery methodologies, i.e., Direct Cost, Shared Infrastructure, and Related Services.

- From a listing of interlocks and DOUs or from Ledger extracts, determine the universe of interlocks and DOUs, select a sample and determine if all elements of the interlock or DOU have been billed per the terms. If interlock or DOU data cannot be obtained and Ledger extracts are used, request the associated interlock or DOU and all internal billings that have been generated. Focus on quarter-end, year-end activity, high-dollar transactions, and special contracts.
- Early in the audit, i.e., first week and a half, arrange interviews with the tower executive, PE's, DPE's for selected Strategic Outsourcing contracts serviced from the SDC to obtain customer feedback. Areas to be considered in the interviews are the following:
 - How, and to which project offices are the costs for your tower/s interlocked?
 - Has the tower documented the interlock process system dependencies, flowcharts and desktop procedures?
 - What measurements/processes do you have in place to monitor that the interlock process is on track?
 - How do you correct any problems with the interlock if any are found?
 - Do you have any major issues with the SDC's management of your cost pool?
 - Do you have any major issues with any of the project offices into which your cost pool is interlocked?
 - What was the result against plan for the prior year cost takeout initiative for your tower?
 - What is the plan for the current year cost takeout initiative for your tower?
 - Is an interlock agreement/DOU in place with all project offices which you service?
 - Is an interlock agreement/DOU in place with the SDC?
 - Have any significant costs previously allocated from your tower/s been questioned, reversed or adjusted?
 - How do you track incoming costs and ensure they are included in the interlock?
- Review local process documentation and process flows. Determine if documents of understanding are required and executed correctly.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Internal Billing (FM002.P)

(Continued)

- Review peer audit / self-assessments for identified exposures and the effectiveness of action plans implemented to correct them.
- Review reconciliation controls and reports to management of unreconciled items.
- Determine if management had visibility to all unbilled transactions, if root-cause analysis was performed, and if corrective actions were taken to ensure completeness of all billing transactions.
- Verify if billing was accurate, timely and authorized. Ensure that billings were adequately supported with relevant details such as headcount, rate, labor hours billed, project ID and account ID.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Ledger Review (FM003.P)

Objective:

To verify that there is a management process to ensure that only properly authorized manual entries and accruals are posted to the general ledger. In addition, the general ledger accounts are reconciled to source documents, interlocks, and documents of understanding (DOU) on a regular basis.

Risk/Exposure:

1. Ineffective journal entry control may enable employees to conceal irregular entries or clear reconciling items from account analysis by writing them off or otherwise disguising the real nature of the activity.
2. Fundamental to the accrual-based accounting process is the necessity to record accrual/provision entries to accurately report IBM's balance sheet or income and expense position. Determining the amounts of these accruals/provisions often involves the use of judgment. However, the foundation for this judgment should be clear documentation and the application of consistent methodologies. The lack of any one of these elements could result in inaccurate and compromised financial statements.
3. Reconciliations, performed correctly and on time, are the primary control to identify any differences between the general ledger and the systems which feed it. In addition, the analysis of the accounts identifies if inappropriate or unauthorized transactions were recorded into the general ledger. Unresolved differences could lead to a misstatement of the company's financial position or diminish the capability to establish controls to prevent fraud situations.

Approach:

Accounting guidelines and assistance may be needed for this scope. The review should be of any journal, accrual, or reconciliation that the audit client has direct requests or impacts on. For example, a cost accrual for labor that a subcontractor under their DOU has performed.

Journals

Select a sample of requested journal entries to determine:

- Was the request clear with appropriate documentation and line approvals prior to submission to finance / accounting for a journal entry to be done?
- Select a sample of entries made on last day and post days of the accounting close to identify any obvious items being concealed or improperly written off.
- Does the journal amount agree with backup documentation and to the accounts that would be expected?

Accruals

Select a sample of accrual/provision entries to determine:

- Was the request clear with appropriate documentation and line approvals prior to submission to finance / accounting for a journal entry to be done?
- Determine if the calculation methodologies were reasonable and were consistent with IBM's accounting guidelines.
- Determine if accruals were reversed on time in the following accounting period and actual revenue, costs, or expenses were recorded as incurred.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Ledger Review (FM003.P)

(Continued)

Reconciliations

The centers may provide input to relevant balance sheet accounts for outstanding items. Request a copy of the balance sheet accounts for the sampled accruals and journals that may require their assistance and review:

- Have the accounts been consistently reconciled for the period selected?
- Were requests for variances between actual expense incurred and planned expense provided to accounting and/or finance as needed to resolve?
- Analyze the documentation for authorization, appropriateness, and timeliness.
- Were action plans, the person responsible for the resolution of aged items and the target date for resolution noted on the reconciliation for variances exceeding 60 days?
- Was management made aware of items which slipped the target date?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Adjustment and Exception Process for Billing (FM004.P)

Objective:

To ensure that billing adjustments are appropriate, processed accurately and in a timely manner, that they include supporting documentation, are approved by management, are reviewed for root-cause analysis, and have corrective action plans that are implemented and monitored.

Risk/Exposure:

The credits and adjustments process is a sensitive phase of the billing process, and if not properly controlled, could impact compliance with IBM's management and business practice guidelines, create exposures to irregularities, and impact processing efficiencies and cost.

Approach:

1. Determine if authorization levels for internal billing adjustments have been established.
2. Obtain a listing of billing adjustment transactions. Select a judgmental sample based on transaction types and dollar values to be determined by the auditor.
3. Determine if all transactions are supported by documentation, approved by management as required, and processed accurately and in a timely manner.
4. Ensure all billing adjustments and unique charges are justified and have supporting documentation.
5. Are all control reports accounted for, complete, and reviewed and approved by management as required.
6. Determine if root-cause analyses for the billing adjustments are being performed and that corrective action plans are implemented and monitored.
7. Determine if there is a management review and inspection process for billing control reports.
8. Verify if the Geo has been communicated for the required adjustment and that intercompany accountant have been provided with the necessary information on time.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Over Under Recovery Process (FM005.P)

Objective:

To ensure that over/under recovery adjustments arising out of Billings at recovery rates are performed accurately, timely and properly approved.

Approach:

1. Select the permanent adjustment entries processed before year end and check for the following:
 - a. Supporting documentation for the entry (performance pack).
 - b. Review performed by the CIC CFO for the over/under recovery to be adjusted and allocated to geo.
 - c. Information to Geo/ about over/under recovery to be adjusted
 - d. Billing adjusted by Intercompany billing Team against ICA.
 - e. Reconcile the actual over/under allocation with the ledger entries. Analyze the variances.
2. Impact of currency exchange rate changes from plan.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Customer Events (FM006.P)

Objective:

To determine whether an effective process existed to ensure that customer events at the CIC were appropriately approved and within budget when the center holds the funding.

Approach:

Note: Customers will request visits of the Client Innovation Centers (CIC) to secure a comfort level to have work performed in the centers. The centers should know who will fund the event, and if it's their cost center, have appropriate approvals for travel and for charging to the relevant opportunity owner as part of the cost center clear out. In addition, the center will assist in ensuring the events are approved using the CTEBA tool, and that the CIC teams are aware and trained on the CTEBA and GOE requirements.

Request a list of customer events for the audit period, request approvals, and ask for the event reconciliation documents (if available) and test if:

1. Were expenses properly identified for the event and approved by the correct parties?
2. Did the funding clearly identify the responsible group with agreement for the cost center to charge at end of event?
3. If the charges went through the CIC, did they close out to the final responsible center?
4. Was a final reconciliation or expense analysis performed and reviewed by management?
5. Were participants to the event within program target and tested against CTEBA requirements?
6. Were GOE (Government Owned Enterprises) participants approved before the event took place?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Capital for Employees and Subcontractors (FM007.P)

Objective:

Have controls been established to monitor, measure, and manage the accurate planning of capital assets. The capital planning process includes the requests for capital, financial reviews, appropriate approvals, planning cycles, and the release of funding by CHQ to the organization being audited.

Approach:

Laptops and servers are likely the bulk of capital requests. Given the headcount movements that occur normally in the CICs, ensure the capital planning and reconciliations are meeting the requirements.

1. Obtain listings showing all requests for capital for the organization during the audit period. This test includes a review of:
 - a. Requests for capital-by-capital projects
 - b. Capital plan as submitted by the organization
 - c. Substitutions by capital projects within the organization to the capital plan and capital released by CHQ
 - d. Select samples from each of the above for the audit period and review for proper documentation, appropriate approval, accurate and timely processing in compliance with policies and procedures, and that exceptions are being addressed to management and resolved.
 - e. Review fixed asset accounting records and test to ensure that completed capital projects have been transferred to fixed asset accounting process.
 - f. Test for exceptions such as early releases and commitments or expenditures made before capital funding was available.
 - g. Determine if reconciliations were reported. If so, select situations to review where reconciliations were not performed, not reviewed by management, or where aged items existed.

Note: Auditors will find different types of financial reporting systems in place across organizations worldwide. As a result, an auditor may find systems that do not easily lend themselves to precise project tracking of expenditures. However, the auditor should obtain adequate documentation to validate the above three capital transactions.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Financial Management

Primary Test: Measurements, and Scorecards (FM008.P)

Objective:

To ensure that measurements, key controls testing, MSA analysis, and scorecard assessments are in place to give management visibility to the quality and timeliness of the operations of their business.

Approach:

1. Obtain local measurement reports for a period to be determined by the auditor. Review attainment against objectives to identify trends and validate performance attainment. If attainment is consistently sub-standard, select a sample of exception transactions and determine the root cause.
2. Obtain all MSA results for each quarter along with supporting evidence of the rating.
3. Obtain scorecards for the audit period including the CIC utilization targets.
4. Obtain measurements on customer satisfaction survey results during the audit period for external and/ or internal customer as part of the process review, subject to sampling.
5. Ensure that there is management visibility to all files reviewed.
6. Have there been significant fluctuations in overall controls performance during the past year?
7. Have there been material changes in expense performance (i.e., decrease/increase in cost/expense, etc.)?
8. Were the CIC utilization targets / measurements all met? If not, were action plans and root cause analysis performed?
9. Was the fall plan completed and reviewed by management?
10. Is there a control process which highlights projects which do not report results within expected financial returns?
 - a. Are all projects included in such an analysis at the individual project level?
 - b. Are actual over/under-applications within established measurement parameters?
 - c. Are projects reviewed to identify if there are contractual issues (e.g., excessive cost due to poor performance against commitments)?
11. Verify the cost and recovery reports, headcount (HC) report, and the utilization reports are included and reviewed by the IBM Consulting GD and GBS WW management.
12. Is the root cause analysis performed for missed targets and actions established to address missed targets?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Resource Management

Objective:

Are there adequate on-boarding and off-boarding process in place to ensure all customer requirements are being met, that staff understands how to protect customer data, that staff members have been properly vetted and trained, and that team members remove all customer data from their possession when leaving an account?

Were there any IBM or local enterprise risks identified related to the IBM services provided within the contracts?

Risk/Exposure:

Non-adherence to customer requirements and internal procedures for staffing engagements could lead to legal exposures, damage to IBM's image, misuse of customer data, disrupt customer business and lead to customer dissatisfaction.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Resource Management

Primary Test: Utilization / Capacity Planning (RM001.P)

Objective:

To ensure that adequate planning and efficient hiring process is in place to avoid delay in resource deployment and project execution.

Risk/Exposure:

Inadequate management review may result in critical headcount and cost issues going undetected, root cause analysis not being performed for missed plans and timelines.

Approach:

1. Review the management reports and analyze the reason for:
 - a. Any delays in hiring reported
 - b. Any execution constraints on hiring the right talent and skills reported
 - c. Follow-up action plan and root cause analysis for failed milestones
 - d. Resources were deployed timely and as per the demand
 - e. Fulfillment status is reviewed for supply demand and bench
2. Review the CIC utilization targets and measurements for achievement.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Resource Management

Primary Test: Onboarding (RM002.P)

Objective:

For CIC audits, the center needs to ensure its meeting the client contractual requirements. All IBM employees, subcontractors and affiliates are responsible for protecting IBM and Client confidential information and PI/SPI/BSI in their workplace. Are there adequate on-boarding processes in place to ensure all customer requirements are being met, that staff understands how to protect customer data, that staff members have been properly vetted and trained, and that any export control delivery restrictions have been identified and accounted for?

Approach:

The following test approach was constructed as a guide to provide direction for achieving the above objective. Please customize your test based on requirements, risks, applicability, and resource availability.

Review contract specific staffing (including vendors) and on-boarding requirements

1. Are there specific requirements that IBM staff and vendors need to follow for a person to be on-boarded to a contract such as non-disclosure agreements, background checks, skill level, certifications, customer orientation, etc.? Understand and ensure requirements are completed before on-boarding. Management must be able to provide evidence that all customer requirements have been met.
2. When do the requirements need to be completed? Are they being completed? Is there evidence of completion?
3. Ensure personnel are claiming correctly in the applicable tool and that onboarding was documented.
4. Have personnel followed policy requirements when on-boarding such as BCG certification, IBM Core Training, etc.?
5. Quantify the risk. Do the personnel have access to any PI/SPI/BSI or customer sensitive data (for example, SPI credit card information for 100,000 customers)? Do personnel know the classification and handling of all customer data that they will have access to?
6. Were all immigration and/or visa requirements documented and available for review if requested?
7. Additional vendor tests to be performed in the Procurement/ Subcontractor section.
8. As required in USERP Section 6 Part 1:
 - a. Was a written confirmation received from the sending organization, as a condition of the workload transfer, that all required export evaluations have been completed and any applicable delivery restrictions have been identified?
 - b. Are secondary controls in place to notify and require the sending organization to provide written confirmation in the event they were not provided as part of the sending country's workload transfer documentation?
 - c. If delivery restrictions were applicable, have controls been implemented by service delivery to ensure compliance with those restrictions?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Resource Management

Primary Test: Off Boarding (RM003.P)

Objective:

For CIC audits, the center needs to ensure they are meeting client contractual requirements. Are there adequate off-boarding processes in place to ensure all customer requirements are being met and that customer applications and data are being protected?

Approach:

The following test approach was constructed as a guide to provide direction for achieving the above objective. Please customize your test based on requirements, risks, applicability, and resource availability.

1. Review all contractual requirements for off boarding requirements for staff (including vendors) and ensure basic off-boarding practices have been followed.
 - a. Are there specific requirements that IBM staff (including vendors) need for a person being off-boarded from a contract such as access removal, badge and equipment return, confidential agreements, timing of off-boarding?
 - b. Do any customers have access to the IBM network? If yes, is there an adequate explanation and procedures for granting, monitoring, and removing that access?
2. Understand and ensure requirements are completed for off-boarding. Sample the universe of personnel that offboarded.
 - a. Ensure personnel are claiming correctly. If in CLAIM and offboarded, has management explained why and if needed, provided evidence of why the team member is still required to claim or offboarded?
 - b. When do the requirements need to be completed and have they been completed in a timely manner? Are they being followed with evidence of compliance?
 - i. Has PI/SPI/BPI and customer data been quantified and cleansed from equipment (for example, laptops, memory sticks, other peripheral equipment)? Is there evidence of cleansing (for example, a signed certificate of cleansing)?
 - ii. Have all required staff/customers been notified and in a timely manner who assist in execution of off-boarding? (i.e., If customer is responsible for removal IBM team was evidence retained of the request and execution?)
 - iii. Do IBMers (including vendors) have access to third-party vendor's network? Verify if removal of network access may mitigate non-removal of application access if the employee cannot access the application without first accessing the network.
 - iv. Has access to systems, environments, network, support tools, and so on been revoked? Have passwords been reset?
 - v. Has client issued equipment (for example, laptops, keys, badges and security tokens) been collected and returned? Any IBM confidential information stored on client issued equipment been removed prior to returning?
 - vi. If applicable, has customer access to any IBM networks been removed if all staff has been off-boarded?
 - c. Do the personnel have access to any PI/SPI/BSI or customer sensitive data (for example, SPI credit card information for 100,000 customers)? Quantify the risk of data cleansing and access removal not performed in timely basis.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Resource Management

Primary Test: Procurement and Subcontractor Management (RM004.P)

Objective:

Are there adequate controls over the process for approving the commitment of IBM funds to external suppliers who are selected based on the criteria set forth in the Procurement Requirements and Practices booklet?

Risk/Exposure:

Failure to properly control the approval of commitments can create excess expenditures, legal problems, vendor relations exposures, and can lead to fraud.

Approach:

Since procurement owns most of the process, these tests are to ensure the requests and approvals required from the line team are being adequately reviewed. In addition, reviews of bypass reports should look to see if the auditable unit is listed to both see the root cause and action plans, along with determining if their process does not ensure use of the procurement guidelines. Finally, the impact of subcontractor requests is going to be large to the overall CIC costs, so those POs are likely to be the primary focus. Review documentation and operation records to validate the control measures listed below. Select a sample of top vendors and purchase orders to confirm effective compliance with the established guidelines.

Overall Procurement Focus

- Are all requisitions using the approved procurement processes?
- Are there adequate controls over the approval process for commitment of IBM funds to external suppliers?
- Review universe files of POs, ECRs, PO Exempts, and IOIs from audit period. Repeat requests for payment to the same supplier and/or from the same requestor could be a sample selection criterion. Verify that non-POs items did not require procurement involvement.
- Review a selection of the travel expense accounts (TEAs) and miscellaneous expense accounts (MEAs) to verify that expensed items did not require procurement involvement.
- Obtain a list of procurement bypasses reported during the audit period. Was the auditable unit on the procurement bypass report during the audit period?
- If yes to bypass, are their action plans documented and implemented to avoid repeat bypasses? If any are repeat offenders, did the action reflect that?

Subcontractor Focus

- Was IBM Procurement engaged as required in the purchase of goods and services from subcontractor firms?
- Is there a valid IBM contract supporting the relationship between IBM and the subcontractor firms?
- Does the subcontractor statement of work (SOW) map to the objectives and deliverables stated in the customer contract.
- As appropriate, based upon access to IBM or customer confidential information, has the IBM Agreement for Exchange of Confidential Information (AECI) been executed by the subcontracting firm and the individual subcontractor with access to the information?
- Are purchase orders created with accurate coding to the appropriate account minor?
- Is subcontractor performance tracked and reported to appropriate management and staff on a regular basis?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Resource Management

Primary Test: Procurement and Subcontractor Management (RM004.P)

(Continued)

- Do appropriate separation of duties (SOD) exist in the management of this supplier relationship. One person should not select the supplier, validate receipt of goods and services, and approve invoices for payment. If an SOD conflict exists, has a risk acceptance with appropriate secondary controls been documented and approved? Additionally, is there documented evidence that the secondary controls have been executed as stated in the risk acceptance?
- Is there a process to validate that subcontractor charges are accurate and are supported by documentation showing the receipt of goods and services? Additionally, if charges are not accurate, is there documentation demonstrating appropriate communications to IBM procurement, accounts payable, and the subcontractor firm? This can be checked in the IPVN process - ask whether negative confirmation or actual demonstration of review of hours worked is required.
- Is there a documented process to verify subcontractor hours worked against hours billed? If so, does the supporting documentation, i.e., timecard, state, "For billing verification purposes only"?
- Are charges for goods and services (invoice payment verification) properly validated prior to payment? Does the rate charged match the rate specified in the contract for the appropriate time period? Please note: rates change periodically. Lastly, is documentation retained in accordance with the IBM worldwide records management program?
- Are subcontractors adhering to IBM guidelines for expense reimbursement? Or, are the subcontractors adhering to the expense guidelines documented in the subcontractor agreement?
- If subcontractor employees utilize IBM assets, does the IBM organization maintain proper asset management controls and reporting for those assets?
- Can the IBM organization demonstrate that security access control requirements are managed appropriately for all subcontractors that are granted access to IBM and customer systems and applications.
- Is ECR (electronic check request) activity minimal and on an exception-only basis? Are ECRs for approved categories only and is supporting documentation retained?
- Has the organization established local processes, flowcharts, and desk-level procedures? Are they reviewed and updated periodically? Does the process documentation include key control points? Additionally, is there evidence that the organization periodically tests the end-to-end process including procurement involvement in subcontractor selection, subcontractor activities, and validation of goods and service prior to payment?
- Have appropriate members of the management team and staff participated in subcontractor management education?

If the organization utilizes a centralized "back-office support function" for performing subcontractor verification and reconciliation activities, is there a letter of delegation or written understanding such as a document of understanding (DOU) communicating the tasks delegated to the organization?

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Labor Claiming

Objective:

To ensure that labor claiming is recorded in a timely and accurate manner. To ensure that labor charges are assigned to the correct work items, rates and bands agree to employee records, and hours are validated against applicable time recording documents and internal interlock agreements. To ensure that there is no SOD conflict on the current process.

Risk/Exposure:

Inaccurate clocking of labor hours could result in significant over or under recovery of cost. In addition, incorrect assignment of labor charges to work items and inaccurate rates and band levels compared to employee records could result in financial misstatement.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Labor Claiming

Primary Test: Applicable Time/Labor Claiming Tool (LC001.P)

Objective:

To ensure that labor claiming is recorded in a timely and accurate manner. To ensure that labor charges are assigned to the correct work items, rates and bands agree to employee records, and hours are validated against applicable time recording documents and internal interlock agreements. To ensure that there is no SOD conflict on the current process.

Approach:

1. Determine if there are written processes or local guidelines for applicable tool
2. Client should be using appropriate labor claiming tool. Exceptions need to be documented
3. Identify the applicable tool administrator(s) and obtain a schedule of the reports published, frequency, distribution list, measurements, review and correction process
4. Obtain a listing of the authority levels from the EMF (employee master file) records
5. Obtain a listing of authorized employees that can claim the hours on behalf of others
6. Determine if there is a revalidation process for users
7. Analyze retroactive adjustments of claimed hours, and the corresponding vendor payment adjustments, in the case of subcontractors

Attributes

1. Obtain a listing of the authority levels from the EMF records
2. Does the EMF record agree with employee/vendor classification and rate
3. Is work performed and are hours charged to work items prior to contract or SOW being signed by customer
4. Verify how Time and Material billable hours controlled
5. Are CLAIM hours verified against the non-exempt time records required for employees and contractors
6. Are there appropriate intercompany agreements (ICA) in place and timely approved to support the cost recovery transactions?
7. Are there appropriate approvals for the number of hour clocked?
8. Are labor claims linked to the correct project code and account ID?
9. Review monthly labor hour reporting and investigate reversals of labor bookings
10. Verify if hours claimed for others are reasonable and reviewed properly
11. Are the retroactive hours/disbursements adjustments material to distort the utilization measurement, over / under calculation or lead to inaccurate vendor payments?

Exception Reports

1. Early claiming
2. Excessive overtime – set clip level
3. Time input by someone different than employee
4. Hours processed outside of the time period
5. Negative hours
6. Modifications to EMF records – rate, band, work item

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Asset Management

Objective:

Were controls effective to ensure assets were acquired in accordance with corporate requirements?
Were assets properly verified, tracked, reported, and retired according to IBM policies and procedures, and customer contractual agreements.

Risk/Exposure:

Failure to control and properly account for asset acquisitions could impact the integrity of IBM's financial statements, personal property tax reporting, and negatively impact customer satisfaction. In addition, if complete reconciliations and physical verifications of all assets acquired under strategic outsourcing agreements were either not performed, or cannot be demonstrated, there is a risk that unreconciled items could result in the loss of IBM and customer assets.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Asset Management

Primary Test: Asset Management (AM001.P)

Objective:

Were controls effective to ensure assets (hardware and software) were acquired in accordance with corporate requirements? Were both customer and IBM assets properly verified, tracked, reported, and retired according to IBM policies and procedures, and customer contractual agreements. Did software assets meet customer contractual agreements and third-party software vendor requirements?

Risk/Exposure:

Failure to control and properly account for asset acquisitions could impact the integrity of IBM's financial statements, personal property tax reporting, and negatively impact customer satisfaction. In addition, if complete reconciliations and physical verifications of all assets acquired under strategic outsourcing agreements were either not performed, or cannot be demonstrated, there is a risk that unreconciled items could result in the loss of IBM and customer assets.

Approach:

1. Review the latest inventory to confirm when it was taken, that it was reconciled to IBM's asset tracking system, that missing assets were resolved or written-off in a timely manner, and that results were reviewed by management on a timely basis.
2. Request a listing of all assets scrapped, retired, sold, or otherwise disposed of during the audit period.
3. Ensure that timely and accurate reconciliations between local asset control files and IBM's asset tracking tools were performed.
4. Ensure that assets are properly recorded in the IBM inventory tracking systems. This includes strategic outsourcing asset databases, Property Control Facility (PCF), Administrative Accounting System (AAS), Electronic Asset Management Tool (e-AMT), and SAP.
5. If a new acquisition or outsourcing deal has occurred, was an initial inventory taken of all contracted assets and was it verified to the applicable contract section? Can agreement with this inventory be demonstrated?
6. Are both IBM and customer asset management obligations under the terms and conditions of the contract clearly defined and customer agreement is obtained and documented?
7. Have the financial records been updated to reflect the retirement? If not, has a reserve been issued?
8. Ensure lost asset checklists support PDAs for the lost assets.
9. Conduct a sample 'floor to book' and 'book to floor'.
 - a. For purchased assets, test for the owner of the asset, location accuracy, asset identifier accuracy between the hardware and the financial records. The asset identifier is what identifies the asset. It can be the IBM machine type and serial number, brass tag number, OEM number, MAC address, etc.
 - b. For leased assets, validate that the owner is correct, that the "installed-at" address of the customer number in the customer master record reflects the accurate location of the asset, and that the customer number is recorded in the financial AED table & is charging to the contract that is using the asset.

SERVICE DELIVERY EXTERNAL - APPLICATION SERVICES

AUDIT PROGRAM #62-10-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Asset Management

Primary Test: Asset Management (AM001.P)

(Continued)

Determine if any assets fall under the roles and responsibilities of the cost center. If yes, define the complete universe of contracts and assets to ensure that all assets are reconciled, verified as being delivered, tracked until capitalized or leased, and tagged with IBM asset numbers (unless machine serial numbers are used for inventory tracking), capitalized or leased at the appropriate costs consistent with the signed contract, and recorded in property control systems (such as eAMT) with the asset owners assigned.

Determine if any contracts have customer contractual agreements and/or third-party software requirements and whether the cost center bears any of the roles and responsibilities. If yes, obtain a listing and:

1. Ensure all software has a current license agreement on file.
2. Determine if software has been installed/billed prior to, or later than, the expiration of the test period specified in the contract.
3. Ensure requests for discontinuance of monthly license charge products are documented in writing, and that discontinuance terms were adhered to.
4. If applicable, for program product offerings in which the price of the software is a function of the hardware to which it is licensed, verify controls exist to sufficiently ensure the proper licensing and billing of software fees. Controls should also exist to ensure appropriate software billing occurs when the associated hardware is upgraded/replaced.